

Industrial Security (Bachelor)

Solution Sheet – Section 05

Threat Landscape

Note. Model answers are deliberately concise (3–8 sentences). Where the question is open-ended, the rubric hint indicates what must be present for full marks. Students may give defensible alternatives to the technique IDs and architectural proposals below; mark on reasoning and source-citation, not on exact ID matches.

Solution

Exercise 5.1 – Stuxnet on ATT&CK for ICS.

Phase	Tactic	Technique ID
USB across air gap	Initial Access	T0847 Replication Through Removable Media
Print-spooler 0-day spread	Lateral Movement	T0866 Exploitation of Remote Services
Signed-driver load	Evasion	T0859 Valid Accounts (<i>or</i> T0857 System Firmware <i>equivalent on Windows kernel</i>)
Step7 ladder injection	Execution	T0843 Program Download
VFD over-/under-speed	Impair Process Control	T0836 Modify Parameter
21-second HMI replay	Inhibit Response Function	T0856 Spoof Reporting Message

Rubric hint: accept any technique ID that is in the right tactic column and supported by Symantec's *W32.Stuxnet Dossier* or Langner's *To Kill a Centrifuge*. Penalise answers that confuse tactics (e.g. calling VFD sabotage "Impact" rather than "Impair Process Control").

Solution

Exercise	5.2	–	Ukraine	2015	vs.	Ukraine	2016.
	2015 BlackEnergy			2016 Industroyer			
Target tier	Three	distribution	oblenergog	Pivnichna	330 kV	transmission	
	(sub-transmission	/ distribution).		substation.			
Human-in-loop	Yes	– operators saw remote attackers move the mouse and click breakers open via legitimate HMI sessions.		No	– malware framework spoke IEC 60870-5-101/104, IEC 61850 MMS and OPC DA directly.		
Automation / protocols	Generic remote desktop / legitimate SCADA HMI access.			Modular, protocol-aware payloads + a SIPROTEC DoS (CVE-2015-5374).			
Recovery	1–6 h outage for ~225 000 customers; weeks of degraded SCADA, manual switching, serial-to-Ethernet converters re-flashed or replaced; KillDisk on workstations; TDoS against call centres delayed restoration.			About 1 h, ~200 MW; smaller in scope but caused by a re-usable <i>framework</i> .			

The 2015 → 2016 transition shows the adversary moving from *hands-on-keyboard* abuse of legitimate tools to *automated, protocol-native* tooling – a step change in capability and a

template for later tools like Industroyer2 (2022).

Sources: SANS/E-ISAC, 2016; ICS-CERT IR-ALERT-H-16-056-01; ESET 2017; Dragos *CRASHOVERRIDE*, 2017.

Solution

Exercise 5.3 – TRITON: a partial defender win.

(1) The attacker likely intended to *silently neutralise* SIS trip set-points (or insert logic that ignores trip conditions) so that a later, separate manipulation of the BPCS – e.g. runaway temperature, over-pressure – would not be caught by the last-resort safety layer, producing a release, fire, or explosion.

(2) The actual outcome was a partial defender win because a payload logic error caused the Triconex to fail-safe trip, shutting the plant down and forcing investigation that ultimately surfaced `trilog.exe` / `library.zip` and led to attribution (Mandiant, 2018; OFAC sanctions of TsNIIKhM, 2020). It remains deeply unsettling because the attacker reached *into* the SIS at all – a long-assumed red line – and the framework was later found at a second victim, so this was not a one-off.

(3) The implant lived in the Triconex controller’s RAM and spoke the proprietary **TriStation** protocol over UDP/1502; few defenders log or parse TriStation, and most EDR / IDS rules know nothing about Triconex internals.

Rubric hint: full marks require naming the SIS / BPCS layering and citing Dragos 2017 or Mandiant 2017/2018.

Solution

Exercise 5.4 – Volt Typhoon and LOLBins.

Four LOLBins associated with Volt Typhoon (per AA24-038A and Microsoft, May 2023):

- `wmic` – WMI command-line, normally for inventory and remote queries.
- `ntdsutil` – AD database tool, normally for DC maintenance / backups (abused to dump `NTDS.dit`).
- `PowerShell` – general scripting / automation; abused for in-memory execution.
- `netsh` – network configuration; abused for port-proxy / persistence (alternatives: `certutil`, `cmd.exe`, `dnscmd`).

Signature-based EDR keys on *what runs* (file hash, known malware string, known IOC); LOLBins are *signed, on-disk, expected* Windows binaries used in expected combinations, so there is nothing to match. The detection class that *can* catch this is *behavioural* / *analytics*: parent–child process trees (`w3wp.exe` → `cmd` → `ntdsutil` is anomalous), command-line argument analysis, baselining of admin-tool usage per host, and identity-based detections (Kerberoasting, anomalous service-account logons). UEBA on authentication and lateral-movement patterns closes the remaining gap.

Rubric hint: accept any defensible LOLBin from the advisory; the key learning is that signatures fail by construction and behaviour wins.

Solution

Exercise 5.5 – PIPEDREAM caught before impact.

(1) Pre-impact discovery matters geopolitically because there is no clean attribution moment and no destroyed asset to point to – both attacker and defender know the tool exists, but no state needs to publicly absorb a hit or escalate in response. It also gives the entire ICS ecosystem (vendors, asset owners, sectoral CERTs) time to harden *before* the weapon is used, which is

unprecedented for an ICS-grade implant.

(2) Pre-built modules covering Schneider M340/M580, Omron NX/NJ, OPC UA and CODESYS, with scanning, parameter changes, logic upload and denial of control, show that a state-sponsored actor has invested in a *cross-vendor platform* – protocol expertise per device family, modular C2, and an attack lifecycle (recon → logic upload → denial) that mirrors mature offensive tradecraft. This is no longer a bespoke weapon like Stuxnet; it is a re-usable kit.

(3) Immediate defensive action: enforce the AA22-103A mitigations – isolate Schneider / Omron / OPC UA endpoints from any routed network, change default and shared engineering passwords, enable multi-factor authentication on engineering workstations, and deploy protocol-aware monitoring on the OT segments hosting those devices.

Sources: CISA AA22-103A; Dragos PIPEDREAM/CHERNOVITE 2022; Mandiant INCONTROLLER 2022.

Solution

Exercise 5.6 – Colonial Pipeline.

Dependency chain: DarkSide encrypted the corporate IT environment, including the *billing and dispatch* systems. Colonial cannot move product it cannot bill or schedule against – volumetric metering, custody-transfer accounting, and the dispatch / nomination function are run in IT, not OT – so the operator halted the pipeline as a business decision, not because the OT controls were down. The five-day outage was driven by the time to restore those IT systems with confidence, not by any OT recovery work.

Two architectural / organisational changes (each with a trade-off):

1. *Hot-standby billing / dispatch in a segmented enclave* with an offline ledger capable of running in degraded mode for N days. Trade-off: duplicated licensing, ongoing data-sync and reconciliation cost, regulatory audit complexity.
2. *Manual / paper-fallback dispatch procedures* drilled regularly, with pre-authorised operating limits so the pipeline can keep moving product at a lower throughput while billing is reconciled retrospectively. Trade-off: regulator and customer acceptance of reduced metering precision; operational risk of running long with degraded telemetry.

Rubric hint: the IT→OT dependency must be named concretely (billing / dispatch / metering). Generic “better backups” is insufficient.

Sources: FBI 10 May 2021 statement; GAO-22-104746.

Solution

Exercise 5.7 – AA23-335A.

(1) **Unitronics Vision** series PLCs (and integrated HMIs), engineering / PCOM protocol on TCP/20256.

(2) Default password 1111; the highest-profile victim cited is the **Municipal Water Authority of Aliquippa, Pennsylvania** (booster station PLC defaced 25 Nov 2023, manual fallback used, no contamination). The advisory makes clear that multiple US water and wastewater utilities were affected by the same access pattern.

(3) CISA’s first mitigation is to *disconnect the PLC from the public Internet* (the advisory then lists changing the default password, enforcing MFA on remote access, and isolating OT). Accept either “disconnect / remove Internet exposure” or “change the default password” as the headline answer.

(4) The decisive initial-access vector was *Internet-exposed PLC* with default credentials – both the door and the key were trivial.

Source: CISA AA23-335A, 1 Dec 2023.

Solution**Exercise 5.8 – Pyramid of Pain.**

From easiest to hardest for the attacker to change:

1. **MD5 hash** – a single recompile or one byte of padding produces a new hash; the attacker pays nothing.
2. **C2 IP address** – new VPS or proxy in minutes; minor cost.
3. **C2 domain name** – requires re-registration, possibly new DNS / TLS certificate; hours to days, modest cost.
4. **Registry-key autorun** (host artefact) – changing the persistence path means changing tooling and operator playbooks; days of work and risk of breaking existing implants.
5. **ATT&CK technique** (e.g. T0855) – forces a different tradecraft; can mean rebuilding payloads, retraining operators, and giving up reliable access.

Implication for SOC's: a SOC that detects only on hashes is detecting only the cheapest thing for the attacker to change; it will see noise and miss every targeted actor. Effective detection must climb the pyramid – behavioural, identity, and technique-level analytics.

Source: D. Bianco, *The Pyramid of Pain*, 2013.

Solution**Exercise 5.9 – Insider IR in 24 hours.**

Containment (hour 0–2). Disable the AD / engineering accounts (do not delete – preserve auditability), terminate active VPN sessions and Kerberos tickets, revoke remote-access tokens, and pull badge access; recover any company-issued laptop and any USB / external drives in possession; freeze e-mail and chat content via legal hold.

Evidence preservation (hour 2–8). Snapshot the engineering server, VPN concentrator logs, file-server access logs, EDR telemetry, DLP events, badge-system logs, and the user's mailbox / chat history *before* retention windows roll over (many SIEMs roll at 7–30 days; VPN logs often shorter). Capture forensic images of any device the engineer used in the last 30 days using write-blockers; document chain of custody.

Notification (hour 0–24). Plant manager and CISO immediately; HR and legal counsel within hours (jurisdictional rules on employee monitoring and consent); process-safety manager because exfiltrated tag/alarm data has process-safety implications; sectoral CERT (e.g. national CSIRT) once exfiltration is confirmed; law enforcement only on legal counsel's instruction, typically after preliminary triage. Vendor PSIRT may also be relevant if proprietary controller config is involved.

Do not confront the suspect, change the locks on their office, or wipe their laptop before imaging it – any of these can destroy evidence, breach employment law, or tip off co-conspirators. Equally, do not announce internally; communications must be controlled.

Rubric hint: full marks require all four blocks (containment, evidence, notify, don't) and at least one mention of chain of custody and one of process-safety review.

Solution**Exercise 5.10 – Open Research.**

Rubric (5 points total).

1. **Decision named, actor named, primary source cited** (1 pt). Source must be one of: CISA / ICS-CERT advisory, vendor PSIRT, peer-reviewed paper, or named journalism / book (Greenberg *Sandworm*, Zetter *Countdown to Zero Day*, etc.).
2. **Operational / commercial reasoning at the time** (1 pt). The student must steelman

the original decision – “they were stupid” is not an answer.

3. **Alternative with its cost** (1 pt). Concrete: capex, downtime, retraining, regulatory exposure, contractual conflict with vendor / integrator.
4. **Counterfactual analysis** (1 pt). Honest assessment of whether the alternative materially changes the outcome or only the margin – e.g. MFA at Colonial *prevents* the initial intrusion; better backups only shorten recovery.
5. **Writing, structure, citation hygiene** (1 pt). No invented sources, no invented body counts, ransom amounts or attribution claims beyond cited material.

Sample exemplar decisions students might pick (non-exhaustive): Colonial’s lack of MFA on the legacy VPN; Maersk’s flat Windows domain pre-NotPetya; the choice not to firmware-update SIPROTEC relays against CVE-2015-5374 before Industroyer; Schneider’s TriStation protocol having no authentication; default-password culture on Unitronics PLCs at US water utilities; EternalBlue-vulnerable hosts remaining unpatched two months after MS17-010.